ANKASEC SİBER GÜVENLİK MÜHENDİSLİĞİ EĞİTİMİ - 2026

201 HAZIRLIK PROJESİ: "Blueprint & The Watcher"

30 MART 2026

METEHAN EROĞLU

Bölüm A: Teori ve Mimari (Research & Logic)

1. **Windows Mimarisi: "Yetki Kimin Elinde?"**

➔ Administrator vs. SYSTEM: Windows'ta Administrator yetkisine sahip olmak ile NT AUTHORITY\SYSTEM olmak arasında ne fark vardır? Neden Red Team operasyonlarında hedefimiz daima SYSTEM olmaktır?

- Administrator yetkisi, sistemdeki çoğu dosya ve kaynağa erişim sağlar; ancak bazı kritik işlemler söz konusu olduğunda bu yetki sınırlı kalabilir. Buna karşılık, System yetkisi çok daha yüksek ayrıcalıklar sunar ve arka plan servislerinden kernel seviyesine kadar geniş bir erişim imkânı tanır. Red Team operasyonlarında System seviyesine yükselmenin temel amacı, EDR gibi güvenlik mekanizmalarını daha etkili şekilde atlatabilmektir.

➔ **UAC (User Account Control):** Ekrana çıkan o sinir bozucu "Bu uygulamanın cihazınızda değişiklik yapmasına izin veriyor musunuz?" (Evet/Hayır) penceresi arka planda güvenliği nasıl sağlar? UAC Bypass ne anlama gelir?

- Windows uygulama yetkilerini 2 şekilde ayarlar Filtrelenmiş Standart Belirteç (Medium Integrity Level) bu filtre kısıtlı yetkilere sahiptir ama Yönetici Belirteci (High Integrity Level) uygulamaya Administrator yetkisi vermektir sistemde köklü değişiklikler (servis ekleme, kayıt defterinin kritik yerlerini değiştirme vb.) haklara sahip olur.
- UAC Bypass ise evet/hayır sorusu gelmeden direk High Integrity seviyesine yükseltilmesidir.

➔ Windows Services (Servisler): Bilgisayarımız açıldığında arka planda sessizce çalışan servisler (Örn: Windows Update) genellikle hangi yetkiyle çalışır? Bu servislerin çalıştırılabilir dosya yollarındaki bir boşluk (Space) neden güvenlik açığı yaratır? (Unquoted Service Path mantığı).

- Windows Update vb. sistemler System yetkisiyle çalışır. Bu servislerin dosya yollarında boşluk bırakılması Unquoted Service Path zafiyetidir. Bu zafiyette dosya yolları adım adım okunur ve boşluğa denk gelince acaba aranan dosya buradamı diye sonuna .exe getirir eğer o kunumdada virüslü bir dosya var ise (Windows.exe tarzı) zararlı dosyayı System yetkisiyle çalıştırır.

2. **Mavi Takımın Gözü: "Sessizliği Bozmak"**

➔ SIEM / EDR Nedir? Windows'un halihazırda kendi "Event Viewer" (Olay Görüntüleyicisi) varken, büyük kurumlar neden ağlarına Wazuh, Splunk gibi harici SIEM/EDR çözümleri kurmak zorundadır?

- Windows Event Viewer, sadece tek bir makinedeki olayları kaydeden pasif bir günlüktür; saldırganlar SYSTEM yetkisi aldığında bu logları kolayca silebilir. Büyük kurumların Wazuh, Splunk gibi SIEM/EDR çözümleri kullanmasının temel sebebi; tüm ağdaki logları silinemeyecekleri merkezi bir sunucuda toplamaktır ve EDR sayesinde zararlı yazılımları Kernel seviyesinde tespit ederek anında otomatik olarak engellemektir.

➔ Gürültülü Araçlar: WinPEAS veya BloodHound gibi keşif araçlarını bir kurumsal ağda çalıştırdığımızda neden Mavi Takım anında alarm alır? "Gürültülü (Noisy) çalışmak" terimi ne demektir?

- Gürültülü (Noisy) Çalışmak, bir saldırı aracının kısa sürede normal bir kullanıcının asla yapmayacağı kadar log üretmesidir. Örneğin WinPEAS saniyeler içinde binlerce dosya ve kayıt defteri anahtarını taradığı için EDR bunu tespit eder. BloodHound ise Active Directory'nin tüm haritasını çıkarmak için Domain Controller'a devasa boyutta LDAP sorguları gönderir bu da bir sürü log düşürür sisteme.

3. Bölüm B: Saha Operasyonu (Blueprint Fights)

Cephe 1: Sistemin Kalbi (Windows İşletim Sistemi)

- **Hedef:** TryHackMe: Windows Fundamentals 1 & 2
- **Görev:** İki odayı da dikkatlice okuyarak tamamlayın. (Özellikle UAC, Services ve Registry kısımları).
- **Beklenti & Raporlama:** * "Task Manager" (Görev Yöneticisi), "Services" (Servisler) ve "Registry" (Kayıt Defteri) bölümlerinin çalışma mantığını kavradığınızı gösterin.
    - Rapora şu sorunun cevabını ekleyin: *"Kayıt defteri (Registry) Windows için neden bu kadar kritiktir ve yanlış bir yetkilendirme (Weak Permissions) bize nasıl hak yükseltme imkanı sunar?"*
- Task Manager (Görev Yöneticisi), Services (Servisler) ve Registry (Kayıt Defteri) Windows’ta birbiriyle bağlantılı üç yapıdır. Task Manager, o anda çalışan program ve işlemleri gösterir. Services, arka planda otomatik çalışan sistem görevleridir ve çalıştıklarında Task Manager’da görünürler. Registry ise sistemin ayarlarının tutulduğu yerdir, hangi servisin veya programın nasıl ve ne zaman çalışacağını belirler. Weak Permissions(Yanlış Yetkilendirme) ise çok sakıncalı bir durumdur yetkisi olmayan bir kişinin o veriyi değiştirmesine kadar gidebilir zararlı yazılımlarda bu cihazı tespit ederlerse bunun üzerinden verileri çalabilirler veya oradan yetki yükseltebilirler.

Cephe 2: Kilit Kırıcı (PrivEsc Mantığı)

- Hedef: TryHackMe: Windows PrivEsc
- Görev: Odanın tamamını çözmenize gerek yok. Ancak "Service Exploits" (Özellikle Unquoted Service Path ve Weak Registry Permissions) başlıklarını dikkatlice okuyup laboratuvar üzerinde uygulayın.
- Beklenti & Raporlama:
- Rapora şu senaryoyu açıklayın: Bir servisin dosya yolunda tırnak işareti olmaması ve yol üzerinde boşluk bulunması (Unquoted Service Path), Windows'un çalıştırılabilir dosyayı ararken nasıl kafasının karışmasına yol açar?
- Bu zafiyeti sömürürken kullandığınız komutları ve terminal ekran görüntülerini kendi açıklamanızla kanıtlayın.

- wmic service get name,displayname,pathname,startmode | findstr /i "auto" | findstr /i /v "c:\windows\\" | findstr /i /v """ komutu ile sistem üzerindeki yollarda boşluklu yerleri buldum.

- ```
  C:\Users\thm-unpriv>wmic service get name,displayname,pathname,startmode | findstr /i "auto" | findstr /i /v "c:\windows
  \\" | findstr /i /v """
  Disk Sorter Enterprise                                                    Disk Sorter Enterprise
        C:\MyPrograms\Disk Sorter Enterprise\bin\disksrs.exe                     Auto
  ```
- Burada C:\MyPrograms\Disk Sorter Enterprise\bin\disksrs.exe yolu gözüküyor, sistem bunu şu şekilde arar:
- C:\MyPrograms\Disk.exe
- C:\MyPrograms\Disk Sorter.exe
- C:\MyPrograms\Disk Sorter Enterprise\bin\disksrs.exe
- Şeklindedir. Eğer bizim düşük yetkili bir kullanıcı olarak bu klasörlere yazma (write) yetkimiz varsa, buraya Disk.exe veya Disk Sorter.exe adında bir zararlı yazılım yerleştirebiliriz. Bu servis arka planda yüksek yetkilerle çalıştığı için, servis başlatıldığında bizim zararlı yazılımımız da doğrudan o yüksek yetkiyle çalışacaktır.
- "C:\MyPrograms\Disk Sorter Enterprise\bin\disksrs.exe" bu şekilde tırnak içinde yazılması gerekiyor. Bu sayede direk tüm yolu arıyacak.

Cephe 3: Nöbetçi Kulesi (Log ve SIEM Temelleri & Wazuh)

- **Senaryo:** Hedef sistemde WinPEAS çalıştırdınız veya yeni bir kullanıcı oluşturdunuz. Mavi takımın ekranına bu hareketler nasıl yansıyor? Görme vakti. Ancak Wazuh paneline bakmadan önce, o panele düşen verinin (Log) ne olduğunu ve SIEM mantığını anlamalısınız.
- **Hedef 1 (Teori):** TryHackMe: Intro to Logs ve TryHackMe: Intro to SIEM
- **Hedef 2 (Pratik):** TryHackMe: Wazuh *(Eğer bu oda ağır gelirse platformdaki "Wazuh" aramasıyla çıkan temel seviye odalara bakabilirsiniz)*
- **Görev:** Önce logların ve SIEM'in mantığını kavrayın, ardından Wazuh ajanlarının (Agents) nasıl çalıştığını ve Dashboard (Panel) okumayı öğrenin.
- **Beklenti & Raporlama:**
  - "Log" nedir ve bir SIEM aracı (Örn: Wazuh) farklı kaynaklardan gelen bu logları nasıl merkezileştirir (Centralization)?
  - "Wazuh Agent" hedef Windows makinesine kurulduğunda, topladığı verileri merkez sunucuya (Manager) nasıl iletir?
  - Bir "Kural (Rule)" tetiklendiğinde Wazuh panelinde bu nasıl görünür? İncelediğiniz loglardan birinin ekran görüntüsünü rapora ekleyerek *"Bu log şu anlama geliyor ve şu kuralı tetiklemiş"* şeklinde detaylıca açıklayın.
- Log bir cihazın meydana getirdiği dijital ayak izleridir.
- SIEM Toplama, Ayrıştırma ve Normalizasyon, Korelasyon şeklinde merkezileştirir:
- Toplama: Tüm logları tek bir yerde toplar.
- Ayrıştırma ve Normalizasyon: Gelen logları aynı formata dönüştürür.
- Korelasyon: İlişkili logları birleştirir ve tek bir senaryoya dönüştürür.

- Wazuh Agent, kurulu olduğu hedef sistemdeki olay günlükleri , dosya değişiklikleri ve diğer güvenlik verilerini sürekli olarak toplar, bu ham verileri işleyip JSON formatına dönüştürür. Ardından, ağ üzerinde dışarıdan okunmaması için TLS/AES şifrelemesiyle paketler ve
  ```

genellikle TCP veya UDP üzerinden doğrudan merkezdeki Wazuh Manager'a gönderir; Manager da bu güvenli paketi teslim alarak analiz için deşifre eder.

BÖLÜM C: İşletim Sistemi Keşfi (Local Recon Adımları)

i. CMD'yi açın ve whoami /user komutu ile SID (Security Identifier) numaranızı bulun.

ii. whoami /priv komutuyla sahip olduğunuz özel hakları (Privileges) listeleyin.

iii. net user [Kullanıcı_Adınız] komutuyla hangi yerel gruplara (Örn: Administrators) üye olduğunuzu kontrol edin.

```
C:\Users\Metehan>whoami /user

USER INFORMATION
----------------

User Name        SID
================ ==============================================
metehan\metehan S-1-5-21-2231121751-357941931-1168248885-1001
```

```
C:\Users\Metehan>whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                       State
============================= ================================= ========
SeShutdownPrivilege           Sistemi kapat                     Disabled
SeChangeNotifyPrivilege       Çapraz geçiş denetimini atla      Enabled
SeUndockPrivilege             Bilgisayarı takma biriminden çıkar Disabled
SeIncreaseWorkingSetPrivilege İşlem çalışma kümesini artır      Disabled
SeTimeZonePrivilege           Saat dilimini değiştir            Disabled
```

```
Yerel Grup Üyeliği                    *Administrators
Genel Grup üyeliği                    *Yok
Komut başarıyla tamamlandı.
```

i. Kendi bilgisayarınızda arka planda çalışan bir servis seçin (Örn: Spooler, wuauserv veya kurduğunuz 3. parti bir uygulamanın servisi).

ii. sc qc [Servis_Adı] komutunu çalıştırarak bu servisin yapılandırmasını ekrana dökün.

```
C:\Users\Metehan>sc qc XblGameSave
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: XblGameSave
        TYPE               : 20  WIN32_SHARE_PROCESS
        START_TYPE         : 3   DEMAND_START
        ERROR_CONTROL      : 1   NORMAL
        BINARY_PATH_NAME   : C:\WINDOWS\system32\svchost.exe -k netsvcs -p
        LOAD_ORDER_GROUP   :
        TAG                : 0
        DISPLAY_NAME       : Xbox Live Oyun Kaydetme
        DEPENDENCIES       : UserManager
                           : XblAuthManager
        SERVICE_START_NAME : LocalSystem
```

- **Bulgular:** Kendi bilgisayarınızda **Unquoted Service Path** (Tırnaksız Servis Yolu) zafiyetine yol açabilecek herhangi bir güvensiz servis tespit ettiniz mi?
- **Sonuç:** Sisteminiz bu spesifik zafiyete karşı güvenli mi yapılandırılmış, yoksa potansiyel bir risk taşıyor mu? Gördüğünüz manzarayı bir Mavi Takım analisti (Savunmacı) gibi raporlayın.

- Unquoted Service Path zafiyeti taşıyan herhangi bir servis görmedim.

BÖLÜM D: Mühendislik Vizyonu (Reflection)

"Yakalanmadan Yükselmek" (Evasion & LOLBAS Mantığı): *Senaryo:* Hedef bir şirketin iç ağına sızdınız. Sistemi analiz etmek için dışarıdan indirdiğiniz winPEAS.exe dosyasını çalıştırdığınız anda ekranda bir hata aldınız. Şirketin EDR sistemi (Wazuh) zararlı/gürültülü dosyayı engelledi, sildi ve SOC ekibine kırmızı alarm gönderdi.

- **Soru:** Bir Red Team (Kırmızı Takım) uzmanı olarak, WinPEAS gibi dışarıdan ("gürültülü") araç getirmeden, sistemde zafiyet aramaya nasıl devam edersiniz? Sadece Windows'un kendi içinde zaten var olan meşru komutlarını (**LOLBAS** - *Living Off The Land* konsepti) kullanmak neden EDR/Antivirüs sistemlerini atlatmada (Evasion) kritik bir rol oynar? Mantığını açıklayın.

2. Çözüm Üretmek (Mitigation & Hardening): *Senaryo:* Windows Privilege Escalation laboratuvarında zayıf yapılandırılmış bir kayıt defteri anahtarı (Weak Registry Permissions) veya tırnaksız bir servis yolu (Unquoted Service Path) buldunuz ve yetkinizi SYSTEM'e yükselttiniz.

- **Soru:** Bir mühendis olarak, sadece açığı sömürmek yetmez, onu kapatmayı da bilmelisiniz. Bu zafiyeti kökten çözmek için Sistem Yöneticilerine (Sysadmin) nasıl bir talimat (Mitigation) verirsiniz? O servisi veya kayıt defterini nasıl "sıkılaştırmaları" (Hardening) gerekir?

- Servisleri kontrol ederim hangisinin yetkisinin yüksek olduğuna bakarım, Kayıt defterini incelerim.

- LOLBAS yetkili imzaya sahip servislerin kötüye kullanılmasıdır bu sistemlerin kullanılması kritiktir çünkü bu servisler sistem tarafından onaylanmış imzaları vardır ve yüksek ihtimal buradan gelen bir saldır EDR/Antivirüs e takılmayacaktır.
- Servis yollarında tırnak içinde olmayanları tırnak içine alırdım ve gurup ilkesi yöntemi kullanırdım bu sayede Unquoted Service Path ve Weak Registry Permissions zafiyetlerinin çoğunu kaldırırdım.